0.1 Đặt vấn đề

Tính đến cuối năm 2025, số mẫu phần mềm độc hại được AV-TEST ghi nhận trên toàn cầu đã vượt 1,2 tỷ, với hơn 450.000 mẫu mới xuất hiện mỗi ngày [1]. Theo báo cáo IBM [2], chi phí trung bình mỗi vụ vi phạm dữ liệu đạt 4,44 triệu USD năm 2025, bao gồm tổn thất do gián đoạn hoạt động, mất khách hàng và chi phí tuân thủ pháp lý. Ở quy mô toàn cầu, thiệt hại do tội phạm mạng được dự báo đạt 10,5 nghìn tỷ USD mỗi năm [3].

Phần mềm độc hại trên Windows tồn tại dưới nhiều hình thức với cơ chế tấn công khác nhau. Ransomware mã hóa dữ liệu và yêu cầu tiền chuộc để khôi phục quyền truy cập; theo Verizon DBIR 2026, Ransomware hiện diện trong 48% các vụ vi phạm dữ liệu [4]. Trojan ngụy trang dưới dạng phần mềm hợp lệ để thiết lập cửa hậu hoặc đánh cắp thông tin; dạng phổ biến là Remote Access Trojan (RAT), duy trì quyền điều khiển từ xa với thời gian tồn tại trung bình 11 ngày trước khi bị phát hiện [5]. Sâu máy tính (Worm) tự nhân bản và lan truyền qua mạng mà không cần tương tác của người dùng. Sự đa dạng về cơ chế tấn công đặt ra yêu cầu về phương pháp phát hiện có khả năng thích ứng với nhiều dạng mối đe dọa, thay vì phụ thuộc vào một cơ chế duy nhất.

Phương pháp phát hiện phổ biến nhất hiện nay là nhận diện dựa trên chữ ký, trong đó hệ thống so sánh tệp cần kiểm tra với cơ sở dữ liệu mẫu độc hại đã biết. Phương pháp này hiệu quả với các mối đe dọa đã biết, nhưng bộc lộ hạn chế trước các biến thể mới: kẻ tấn công có thể tạo biến thể bằng cách đóng gói lại hoặc làm rối mã thực thi, khiến chữ ký hiện có không nhận diện được. Theo SonicWall, chỉ trong năm 2024 đã có hơn 210.000 biến thể mã độc mới được phát hiện [6], phản ánh khoảng trễ liên tục giữa thời điểm mẫu xuất hiện và thời điểm chữ ký được cập nhật.

Hạn chế này đặt ra nhu cầu về phương pháp phát hiện không phụ thuộc hoàn toàn vào chữ ký, có khả năng nhận diện cả biến thể chưa từng xuất hiện (zero-day). Kết hợp phân tích tĩnh bằng học máy và quan sát hành vi động trong môi trường sandbox là hướng tiếp cận cho phép hệ thống nhận diện cả mẫu đã biết lẫn biến thể mới.

0.2 Mục tiêu và phạm vi đề tài

Từ hạn chế của phương pháp phát hiện dựa trên chữ ký đã phân tích tại Mục 0.1, đồ án xây dựng hệ thống hỗ trợ phát hiện và phân tích phần mềm độc hại trên nền tảng Windows. Hệ thống thực hiện phân loại tệp thực thi là lành tính hay độc hại. Bên cạnh đó, hệ thống thu thập thông tin phục vụ phân tích hành vi gồm chỉ số xâm phạm (IOC), cây tiến trình và các kỹ thuật tấn công theo khung MITRE

ATT&CK [7]. Ba dạng đầu ra này bổ sung cho nhau: IOC phục vụ truy vết và đối chiếu nhanh, cây tiến trình giúp hiểu luồng thực thi, ánh xạ ATT&CK chuẩn hóa kết quả cho đội ngũ phân tích.

Đồ án giới hạn phạm vi đối với các tệp thực thi định dạng PE 32/64-bit (`.exe`, `.dll`) trên hệ điều hành Windows. Các định dạng khác như tài liệu Office chứa macro, script PowerShell hay JavaScript, cũng như các nền tảng ngoài Windows, không thuộc phạm vi đề tài. Đồ án không đặt mục tiêu xử lý các kỹ thuật né tránh sandbox nâng cao hay cơ chế chống phân tích chuyên biệt.

0.3 Định hướng giải pháp

Để đạt được các mục tiêu đề ra, đồ án đề xuất kiến trúc hai giai đoạn kết hợp phân tích tĩnh và phân tích động. Giai đoạn tĩnh thực hiện phân loại tệp PE thông qua mô hình học máy huấn luyện trên các đặc trưng cấu trúc. Giai đoạn động thực thi mẫu trong môi trường sandbox cô lập nhằm thu thập thông tin hành vi thực tế. Phân tích tĩnh đơn lẻ dễ bị vô hiệu hóa bởi kỹ thuật đóng gói và làm rối mã; phân tích động đơn lẻ tiêu tốn nhiều tài nguyên và không cung cấp phân loại tức thời. Kết hợp hai giai đoạn cho phép hệ thống phân loại nhanh dựa trên cấu trúc tệp, đồng thời thu thập bằng chứng hành vi để làm rõ ngữ cảnh tấn công.

0.4 Bố cục đồ án

Phần còn lại của đồ án được tổ chức như sau. Chương **??** trình bày cơ sở lý thuyết, bao gồm đặc điểm các nhóm mã độc phổ biến, cấu trúc tệp PE và đặc trưng tĩnh, cơ chế thu thập sự kiện qua Sysmon và ETW, và khung MITRE ATT&CK. Chương **??** trình bày kiến trúc tổng thể, quy trình xây dựng mô hình học máy, thiết kế môi trường sandbox và cơ chế xây dựng chuỗi hành vi. Chương **??** trình bày triển khai từng thành phần và giao diện web demo. Chương **??** đánh giá hiệu năng mô hình phân loại và kết quả phân tích hành vi động. Chương **??** tóm tắt kết quả đạt được và đề xuất hướng phát triển.